

Advice About Cybersecurity and Privacy

Daniel Hardman

2023-06-06

Abstract

A practical guide to cybersecurity and privacy for non-experts, offering distilled advice on browsers, passwords, antivirus, software installation, two-factor authentication, and more.

Advice About Cybersecurity and Privacy

6 June 2023 (*last reviewed Feb 2025*)

As a CISO and cybersecurity professional, I wrote this for family and friends who wanted a list of reasonable measures that would help improve their online safety. Later, I decided to publish and maintain the post as a reference for anyone with similar questions. My caveats: These are deep topics, and it would be easy to list hundreds of best practices. I don't do that, not because I am unaware of more ideas, but because I am trying very hard here to distill to what's practical and has a high payoff for ordinary adults. Also, I am certainly not all-wise in this space, so your mileage may vary. Feel free to send me comments and suggestions.

Use a browser that's strong on privacy and cybersecurity

Two reasonable, mainstream choices are Firefox and Brave. Brave is built on the same foundation as Chrome, runs Chrome extensions, and is virtually identical to Chrome in every way, except that it doesn't track you for Google — but you have to turn off certain ads. Browsers I would avoid: Chrome, MS Edge, Samsung Internet, etc. I am ambivalent about Safari. It's definitely better than the bad category. Opera might be good; I don't know. The TOR browser is more specialized. It has some advanced features, but if you know all about it, you probably don't need this document. 1. Go to <https://coveryourtracks.eff.org> and run the self-test to see if your browser is preventing you from being tracked. 1. In your browser, configure the default search engine to be DuckDuckGo or similar, so your searches aren't used to build a huge profile about you. I would particularly avoid using Bing or Google. 1. Think long and hard about whether you want to log in to your browser to use a “sync” feature across all your devices. Such a feature requires someone to know all your browsing behaviors. Do you trust whoever is doing that service for you?

Manage passwords carefully

This is a big topic all on its own. A few basic principles:

Length is FAR more important than any other property

First, prefer passkeys. If not that, then prefer long, generated random secrets. They're great, if you don't have to remember them (see password managers below). If you need to remember, use pass *phrases*, not pass words. "May the 4th be with you, Luke" is a WAY, WAY better choice than "GqM0724*" (your initial + birthday + a special character). Hackers have computers that can guess maybe a trillion passwords a second. If so, the 8-char example password will be found by brute force after about 8^{64} guesses (less than 5 minutes). On the other hand, a good 30-char pass phrase would take about 10 billion, trillion years. Cutesy substitutions (e.g., 4 for a capital A, 3 for a capital B) do NOT help; length does, and it has an exponential benefit. Phrases are much easier to remember than random combinations of letters, and they make long values easy.

Don't re-use passwords on multiple websites

If this feels impossible — you can't imagine remembering hundreds of unique passwords — then see the next suggestion. But if you *must* reuse passwords, at a minimum, DO NOT re-use your email password or your online banking password anywhere else. Your email is used as the password recovery for most other accounts; it MUST be different from all others.

Use a password manager

The best of these allow you to safely share passwords with your spouse or children, they can be used on all your devices, and they encourage the other good habits I'm recommending. Two that I suggest: 1Password and BitWarden. LastPass is free and is not bad (but has made some clumsy mistakes lately). PassPack isn't bad. The password managers built into your browsers or mobile OS may be adequate, but I tend not to want to let Google or Apple know all my secrets. Turn off the "remember passwords" feature in browsers unless the browser is the password manager you're using.

Use antivirus

There are many reputable apps that offer a free version: Norton, McAfee, Avast, BitDefender, AVG, Avira, Malwarebytes, etc. They all try to sell you a premium upgrade. You should be aware that many of these programs are heavy — they use a lot of resources on your computer — and that this heaviness gets far worse if you turn on all the bells and whistles. I currently run the free version of Malwarebytes, and I don't accept the upgrade offers because I don't want that heaviness. The basics are vital; the extra stuff isn't, IMO.

Be leary about installing extras

Installing software is the single most dangerous thing you do on your computer; it is like unlocking your front door when you know criminals are trying to sneak in. (Updating existing software doesn't count as dangerous; that's actually a good habit.) Uninstall any app you don't use; on a phone, if you can't uninstall something useless, see if you can at least disable it or remove the icon from your desktop.

Software that comes from big companies you've heard of is safe, if you get it from a canonical location (e.g., microsoft.com, the app store, the play store), but NOT if you download it from

a distributor. Specialized apps can also be fine, but check their reputation. (How many downloads/users do they have? Has a friend used it for years?) Especially, DO NOT install extra toolbars or extensions for your browser unless someone whose judgment you trust recommends them. Porn and gambling are malware magnets, BTW.

Run 2FA (aka MFA)

Preferably, do this everywhere. At the very least, do it on your email and online banking. This is the process where, when you login, you get an email or text with a 6-digit code that's also required to complete the login. A fancier version of this uses an authenticator app to give you the 6-digit code. Optionally, if you use a good password manager, it can provide these 6-digit codes, replacing SMS messages.

Be very careful of public computers

It is dangerous to sit down at the public library or in the business center at a hotel and log in to your personal email, because the computer could be running a keystroke logger, and your login leaves evidence behind that a hacker could use. If you must use a public computer, use a private browsing session (aka incognito mode) in the browser; this at least guarantees that when you close the browser window, everything is cleaned up carefully.

Follow the “don’t call me, I’ll call you” rule

This will protect you from a huge number of possible scams. All of them follow a similar pattern: someone who seems authoritative reaches out to you, out of the blue, to get you to take an action that is dangerous. “Dangerous” means things like:

- opening or viewing an attachment
- logging in or paying by clicking a link or button in an email or SMS message
- installing anything (run away!)
- disclosing passwords or personal data

Use some common sense here. Microsoft does NOT pay support personnel to call customers whose computers are infected with a virus, and banks do NOT pay employees to call customers about hacked accounts. First, these companies are not that well informed. Second, that kind of operation is extremely expensive; any company who has a paid support staff is trying hard to minimize the time their staff spends on the phone, rather than encouraging them to drum up new business. And fourth, those companies already have a standard, (semi-)safe channel for interacting with customers — their website and/or their app. If they need to tell you there's a problem, they'll do it when YOU decide to come to their website or when YOU open their app — they won't usually go out of their way to get your attention using a new channel.

There are exceptions, but they're not mysterious. If you get an email from a website where you just barely created an account, and it asks you to verify your email, this is fine. If you reset your password and get a confirmation text 30 seconds later, this is fine. If you get an email or text about an order that you just placed on Amazon, that's probably legit, too. In these cases, YOU did something first, so you can expect part 2 of the interaction. Also, if these emails contain links that take you back to their website, there's close to a 100% chance that you WON'T be prompted to login again, since you were logged in just before. In contrast, if the action in the email or SMS

leads you to provide username / password, and it's not one of these exceptions, that's a serious red flag.

If you're ever unsure, fall back on the rule as stated: "Don't call me, I'll call you." If you are dealing with someone legitimate, it should ALWAYS be possible for you to reconnect to them by starting the interaction on your side, using something OTHER than a special link they give you. Ask them to tell you how to reconnect to them by browsing to the right place on their website. Then do that.

Clicking on attachments in email or chat conversations is one of the riskiest things you can do. Remember: phone numbers and email addresses and social media accounts can be spoofed — or they can truly belong to your friends, but be hacked and become malicious. It's safe to read text. Anything more should require very strong confidence about context. Be especially careful when presented with password-protected .zip files, weird friend requests, PDFs you didn't expect, demands of payment, and buttons in email messages. Buttons in email that do trivial things like verify your email might be okay, but buttons that lead to a login anywhere requiring with high privileges (e.g., your bank) are a huge red flag. If the result of clicking a button or an attachment is a login prompt or a request for permissions, or if an installation begins, STOP IMMEDIATELY.

(You might establish a code word with family and friends to decrease the callbacks: "If you ever want me to know that something iffy really comes from you, just put the word '*nightshade*' in the message. That will save a phone call.")

Monitor your reputation and breaches

Go to haveibeenpwned.com (Yes, I spelled that right; "pwned" is a gamer term that means "completely dominated" and suggests you're a hacking victim). Look up your email to see if you're known on the dark web. Chances are very high that the answer will be yes. Scroll down and find the advice about how to improve things. Notice the link to subscribe to updates. I do that. This generates periodic emails that tell me about new breaches. If you are ignoring point 2.b (don't reuse passwords), then you MUST change passwords immediately on every website that uses the same password as the one that had the breach. You may also want to change your email password as a precaution, with some breaches.

If you use any Google services, occasionally take their privacy checkup

Go to myaccount.google.com. Turn off all the data collection that Google does on you, or as much as you can stand — your youtube watch history, your geolocation in Google Maps, your search history, etc.

Plan for your digital death or incapacitation

Make sure that someone will inherit access to your email when you die or when you're in a coma, so they can use password reset on all your accounts to get access if needed. Google's Inactive Account Manager is a good idea, if you use Google/GMail.

Advanced Advice

A whole bunch of other things could be said. I've put stuff below here into the advanced section because the return on investment is lower, and/or the knowledge requirements are higher.

Limit cookies

If your browser prompts you about what cookies you want to accept (common in Europe, California, etc.), choose "Reject All" or something like that setting. Don't habitually click "Accept All." You can also get some of this benefit by browsing in private sessions / incognito windows. If you use an Android device, consider occasionally resetting or deleting your GAID (a unique number that identifies your device): Settings > Google > Ads.

Pay attention to the security of your home wifi router

Give it a strong password. Once a year, make sure its firmware is patched. (Calendar reminders are your friend.)

Consider using a VPN

This can hide your physical location (or change it as needed). It can also make it harder to fingerprint your home network and hardware. ProtonVPN and ExpressVPN are good choices.

Consider making your email more private

You can use a free service like Proton (but might have to pay to upgrade available storage). You may also want to use Firefox's Private Relay and mail mask service.